

Vulnerability Research Report

Repository-Wide Broken Access Control and Predictable PDF Exposure in SMAP Online Portal

Date	April 16, 2026	Researcher	Ahmed Awadh Mohammed Gubran (BI210023)
Affected System	UTHM Student Portal (SMAP Online)	Affected Component	Files Repository (/bio/repository)
Severity	Critical	Vulnerability Type	Broken Access Control / IDOR / Predictable Filename Generation

Primary evidence: File 8 is labeled *Restricted Mode* in the Files Repository interface, yet it was retrieved successfully after its filename was derived.

Executive Summary

A critical weakness was identified in the UTHM Student Portal Files Repository module. Multiple student PDF documents appear to use a deterministic, Base64-based filename generation pattern and are delivered through direct URLs without effective server-side authorization. Based on observed repository entries, the affected document set may include student confirmation letters, an English-language certificate copy, and a graduation confirmation document. The strongest proof is File 8, labeled *Restricted Mode* in the interface, which was still retrieved successfully after its filename was derived.

1. Affected Component and Scope

The affected component is the **Files Repository** module accessible under */bio/repository*. The repository list shows multiple PDF documents associated with the student profile.

- Student confirmation letters (Surat Pengesahan Pelajar)
- English-language certificate copy (Salinan Sijil Bahasa Inggeris)
- Graduation confirmation document (Surat Pengesahan Graduan)

Based on the observed behavior and retrieved document naming structure, repository-served PDFs appear to follow the same deterministic naming scheme and direct file delivery logic. The exposure therefore appears to extend beyond a single file.

Repository Uploaded files			
Message			
Please check the uploaded files.			
FILES UPLOADED			
#	FILE NAME	DATE UPLOADED	ACTION
1	Surat Pengesahan Pelajar	20-MAY-24	View
2	Salinan Sijil Bahasa Inggeris	04-SEP-24	View
3	Surat Pengesahan Pelajar	17-DEC-24	View
4	Surat Pengesahan Pelajar	24-FEB-25	View
5	Surat Pengesahan Pelajar	06-MAY-25	View
6	Surat Pengesahan Pelajar	04-NOV-25	View
7	Surat Pengesahan Pelajar	27-JAN-26	View
8	Surat Pengesahan Graduan	12-MAR-26	Restricted Mode

Figure 1. Files Repository interface showing multiple PDF documents, with File 8 labeled Restricted Mode.

2. Main Findings

2.1 Predictable filename generation

Document references appear to follow a deterministic pattern: Base64(Student_ID + Date_of_Generation + Precise_Timestamp).pdf. Because the values are structured and time-based rather than randomly generated, valid document references can be derived within a narrow window once the pattern is understood.

2.2 Broken access control at the file delivery layer

When a valid document URL is requested, the server appears to return the PDF without reliably verifying whether the requester is authorized to access that specific document. The protection is therefore applied in the interface, not fully enforced by the backend.

2.3 Retrieval of restricted File 8

The clearest proof is File 8, shown as Restricted Mode in the repository interface. Although it was not available through normal navigation, it was still retrieved after reconstructing its filename. This demonstrates that a hidden or restricted status in the portal does not prevent direct access if the underlying resource path can be derived.

3. Technical Evidence

Step 1. Pattern recognition

The vulnerability was initially identified through comparative structural analysis of repository-served document references. Review of the observed filename structure revealed a strong correlation between document identifiers generated through the same workflow.

Base64 decoding showed that the underlying payloads followed the same structural pattern and differed only by a one-second timestamp increment. This indicated that the system uses a deterministic naming convention rather than a secure random identifier. The observed logic follows the pattern:

Base64(Student_ID + Date + Precise_Timestamp)

Sample payload (redacted):

[REDACTED_STUDENT_ID]20260312104444

Ethical Scope and Research Integrity

All subsequent validation and testing were strictly limited to the researcher’s own student profile. The observed naming logic was used only to reconstruct the URL of the researcher’s own File 8, which was marked as restricted in the user interface, in order to validate the access control weakness.

No attempts were made to derive, enumerate, or access document URLs belonging to other students or third parties.

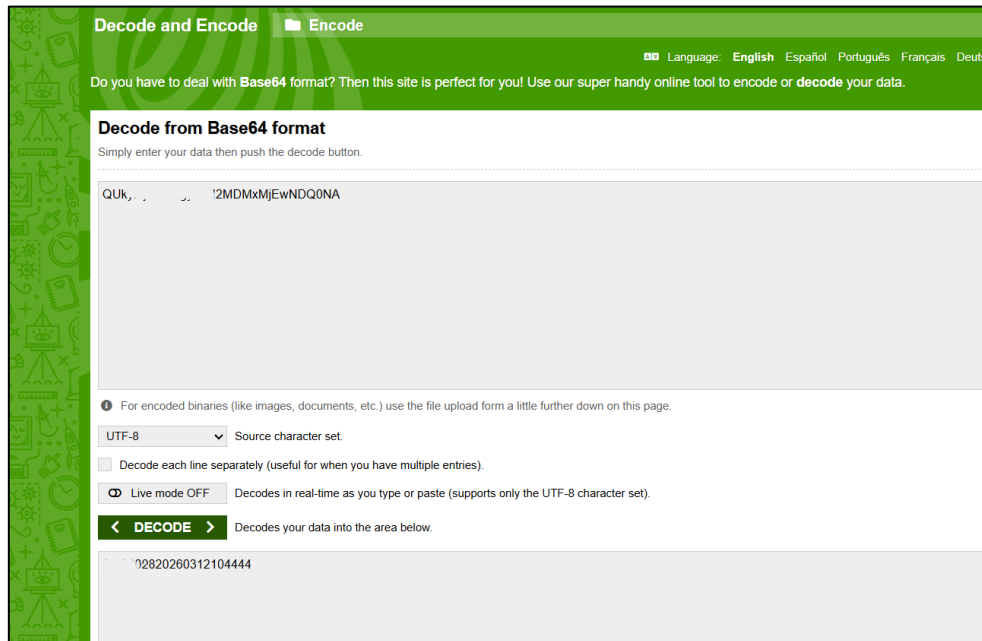


Figure 2. Redacted decoding view is used to confirm the deterministic payload structure.

Step 2. Controlled validation

A limited validation process was used within a narrow timestamp window to confirm that the naming pattern was predictable in practice. The validation identified a valid document reference without requiring broad enumeration. Result: a matching record was confirmed at timestamp **10:44:45**.

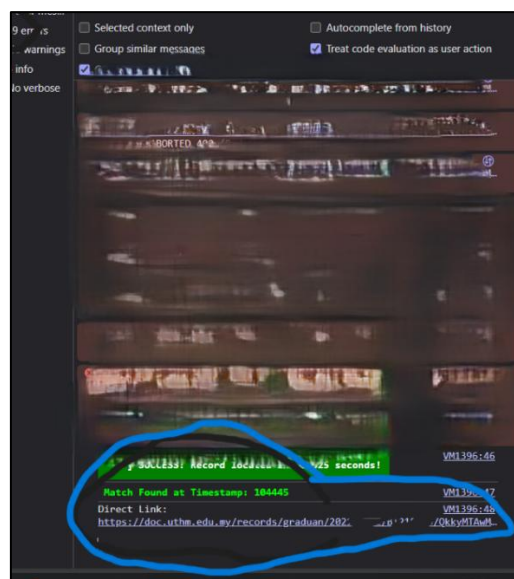


Figure 3. Validation output confirming a successful timestamp match; the direct link is redacted.

Step 3. Direct retrieval of File 8

Using the derived naming logic, File 8 was requested directly and opened successfully despite being marked as restricted in the portal interface.

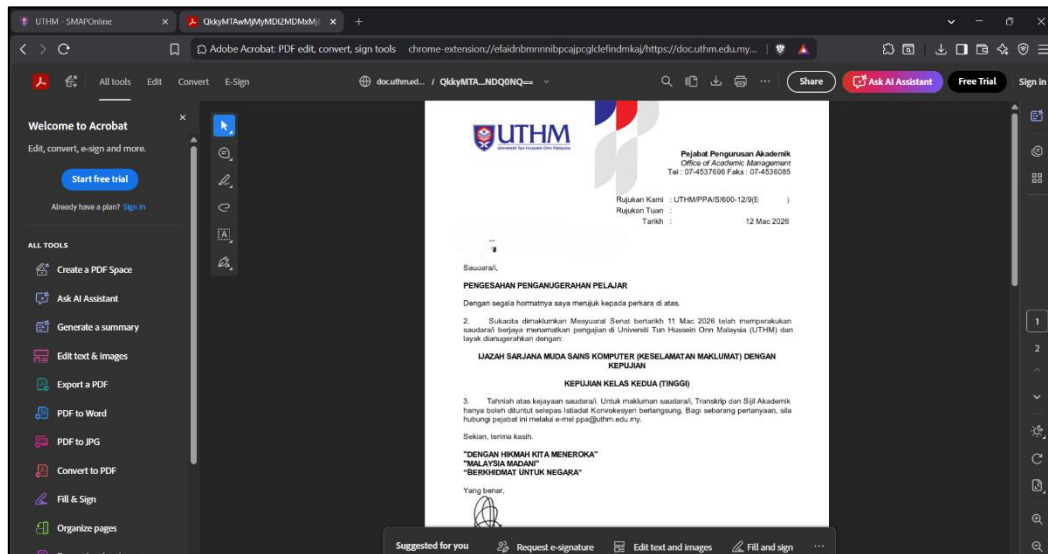


Figure 4. Restricted File 8 was retrieved successfully after reconstruction of its filename.

Step 4. Private-session verification

The same document was then opened in a private browsing session and served directly, indicating insufficient authorization enforcement at the file delivery layer.

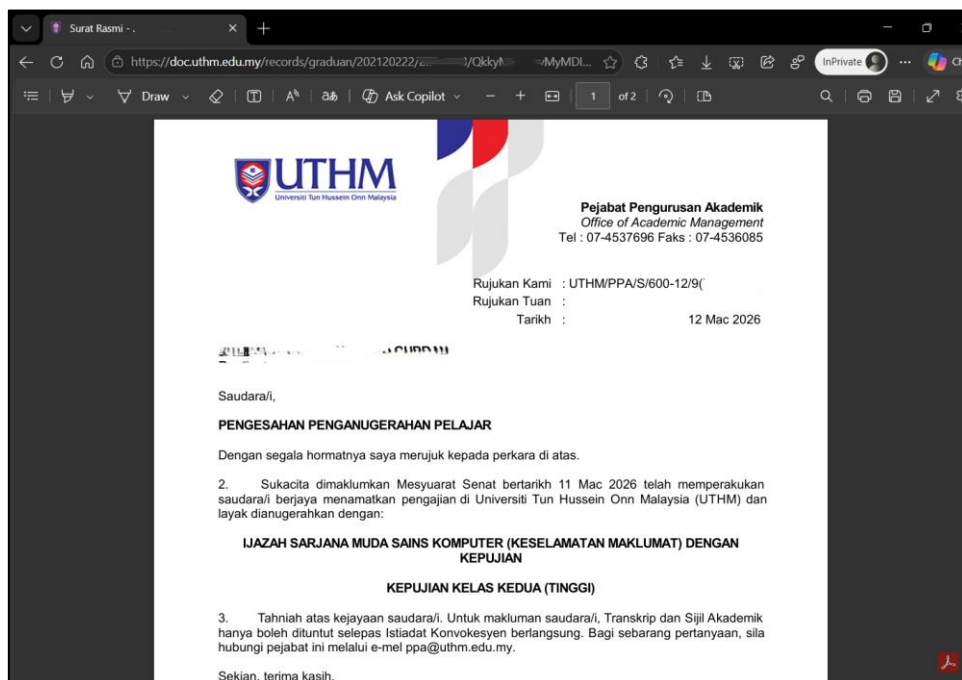


Figure 5. The restricted document remains accessible in a private session once the direct URL is known.

4. Impact

- Unauthorized access to repository-served student PDF documents.
- Exposure of personally identifiable information (PII) and academic-supporting records.
- Retrieval of files that appear hidden or restricted in the user interface.
- Potential for repeated or automated harvesting of multiple records if not remediated.

5. Recommended Remediation

- Replace deterministic filenames with cryptographically random identifiers such as UUIDv4 or opaque tokens.
- Enforce server-side authorization for every document request and validate ownership before serving any file.
- Deliver sensitive PDFs only through protected application endpoints, not direct public file paths.
- Audit and revoke existing directly accessible document URLs; regenerate or reissue protected references where necessary.
- Add request logging, monitoring, and rate limiting to detect repeated access attempts.

6. Conclusion

The issue appears to affect the Files Repository module, not only a single graduation document. The successful retrieval of File 8, despite its Restricted Mode label, shows that interface-level restriction is not sufficient when the backend serves predictable resources without robust authorization checks. Immediate remediation is recommended.

7. Classification References

- **CWE-639** — Authorization Bypass Through User-Controlled Key
- **CWE-200** — Exposure of Sensitive Information to an Unauthorized Actor
- **CWE-425** — Direct Request / Forced Browsing
- **OWASP Top 10** — Broken Access Control